

the risks of these options. These may be used to mitigate disruptions, allow an orderly power down of systems, or transition systems to a longer-term alternate power source.

- Processes to power down IT systems in an orderly manner to maintain critical information for later recovery, in cases where power cannot be maintained (e.g., during emergencies).
- Automated emergency lighting that activates to illuminate the entity's critical infrastructure, evacuation routes, and emergency exits, in the event of a power outage or disruption.

V.E Physical Access Controls

Physical access controls are mitigations that protect an entity's facilities, physical assets, and technology assets.⁷⁰ Unauthorized access can negatively affect the confidentiality, integrity, and availability of the entity's information and technology assets and the business operations supported by them. Therefore, management should consider physical access controls when building or modifying an entity's infrastructure environment. Management should implement appropriate physical access controls such as the following for the infrastructure and for locations that house the infrastructure:

- Generate and maintain a list of approved individuals with authorized physical access to the facilities housing IT infrastructure.
- Validate access authorizations before granting access to restricted spaces (e.g., data centers, computer rooms, and sensitive work areas).
- Issue credentials (e.g., badges, ID cards, and smart cards) for entity personnel and visitor badges for non-entity personnel (e.g., third-party service provider personnel).
- Maintain and review logs of individuals that access restricted spaces.
- Monitor physical intrusion alarms and surveillance equipment.
- Escort visitors and monitor visitor activity.
- Secure combinations, keys, and other physical access devices, and change combinations or keys when combinations are compromised, keys are lost, or staff is transferred or terminated. Any electronic user credentials should be removed or updated in a timely manner.
- Review inventory of physical access devices at regular intervals.
- Review access lists regularly and remove access for individuals who no longer require access.
- Implement alternative physical access processes in case electronic controls fail (e.g., during power failures).

⁷⁰ Refer to [NIST SP 800-53 Rev. 5, Security and Privacy Controls for Information Systems and Organizations - PE-3 Physical Access Control](#).

VI OPERATIONS

Operations are the performance of activities comprising methods, principles, processes, procedures, and services that support business functions. For the purposes of this booklet, IT operations include the tactical management of technology assets and daily delivery of services to capture, transmit, process, and store transactions and information that support the entity's overall business processes.

The operational environment includes the systems and facilities that the entity uses to run its business processes and operations. Operations functions are sometimes referred to as "back-office" functions because they are traditionally carried out in locations away from customer-facing functions. Operations functions are the "nerve center" of an entity and encompass the day-to-day processing and support functions, service delivery and service management, and control processes to support both the operations and overall mission of the entity. The operational environment is addressed in the following subsections:

- Operational controls.
- IT operational processes.
- Service and support processes.
- Ongoing monitoring and evaluation processes.

VI.A Operational Controls

Action Summary

Management should develop and implement operational controls to safeguard the entity's operational environment. These controls should be designed to protect the overall environment, including the physical facilities, infrastructure supporting the entity's operations, systems and software, and personnel.

Examiners should review for the following:

- Effective controls over the entity's operating centers, including physical and logical controls.
- Defined and appropriately administered authorization boundaries containing the entity's systems, software, and information.
- IAM methods used to appropriately identify and authenticate authorized users.
- Personnel controls (e.g., hiring and retention practices, maintaining appropriate skillsets and knowledge, and activity monitoring processes) to maintain an effective workforce.
- Controls allowing for the use of personally owned devices.

Operational controls are the day-to-day procedures and mechanisms used to protect operational systems and software. Operational controls affect the system and software environment. Because

the system and software environment(s) are the foundation for the entity's business processes, management should define processes and implement controls to protect the entity's operational environment(s). This includes the use of operating centers, authorization boundaries, IAM controls, personnel controls, and controls for the use of personally owned devices.

VI.A.1 Operating Centers

Operating centers can be physical or cloud-based and either entity-owned or outsourced. In entity-owned operating centers, management is responsible for the physical location as well as the on-premise equipment and systems. Operating centers may be owned and managed by a third party or may be on the entity's premises but managed by a third party. In outsourced operating centers, management may be responsible for the equipment, but not the physical location. If a third party is involved in operating center activities, the contract should specify equipment ownership and responsibility. Regardless of the operating center type or its ownership, management remains responsible for the oversight of those activities. Typical operating centers include the following:

- **Data center:** The location where the entity houses and maintains its processing, data, storage, and communications systems and equipment. Data centers may be on premise, at a third-party location, co-located, or operate in the cloud.
- **Network operations center (also referred to as NOC):** The NOC is the organization responsible for monitoring the health and performance of the network, including analyzing and maintaining network traffic.
- **Security operations center (also referred to as SOC):** The SOC is the organization responsible for monitoring the entity's network for security issues and responding to cyber attacks.

In smaller or less complex entities, there may not be separate operating centers. For example, the entity may have only a server room or closet. The key responsibilities and functions (e.g., security and network management) in operating centers should still be addressed.

Management should maintain operating centers in physical locations less prone to environmental threats (e.g., away from flood plains or terrorist targets). Management should use appropriate security and environmental controls within its infrastructure to meet the entity's operational needs:

- Smoke, water, and power detection and mitigation devices and systems, as well as fire suppression systems.
- Security zones to limit access within restricted spaces.
- Physical security controls (e.g., security partitions that reach the ceiling and windows that do not open).
- Devices to restrict and log access to the site (e.g., badges, access cards and systems, keypads, and cameras).
- Procedures outlining appropriate site maintenance (e.g., dust-free environment, limitation of paper or cardboard box storage, and restrictions on flammable chemicals or materials).

Management should designate responsibilities for implementing these security and environmental controls. Whether centralized or decentralized, operating center responsibilities also should include training staff to operate and maintain the entity's equipment and systems (e.g., monitoring of environmental systems and procedures for manual intervention and overrides), deploying appropriate connectivity, and managing incidents and events. As part of its responsibilities, operating center personnel often provide logistical support for disaster recovery and business continuity testing for the operating center and business lines. Logistical support may include switching processing from production to alternate sites and systems. Refer to the *IT Handbook's* "[Business Continuity Management](#)" booklet for more information.

VI.A.2 Authorization Boundary

An authorization boundary is important in maintaining the confidentiality, integrity, and availability of the entity's sensitive customer and corporate information. Within each boundary are discrete, identifiable technology assets that represent the building blocks of the information system. In conjunction with the entity's ITAM inventories, management should define the necessary authorization boundaries and implement appropriate security controls. Maintaining multiple authorization boundaries can help mitigate the spread of malware infiltration during a breach. Management should implement appropriate controls (e.g., VPN or demilitarized zone) over internal and external communication systems within and across the entity's authorization boundaries and with third parties (e.g., service providers and other external entities).

Authorization boundaries are composed of the following:

- Physical, logical, and environmental controls.
- Perimeter protection devices.
- Internal and external communication systems.
- People and processes supporting the entity's missions and business functions.

Defining authorization boundaries provides management with the ability to centrally and consistently manage its systems and facilities. It enhances visibility across the entity's segmented infrastructure and operations environment for mitigation, maintenance, and incident response within a particular authorization boundary.

VI.A.3 Identity and Access Management

IAM encapsulates people, processes, and products, including technology, to identify and manage the data used in an information system to authenticate users and grant or deny access rights to data and system resources. Management should implement appropriate IAM to provide access to the entity's resources. Given the sensitivity of the data residing on the entity's assets, management should consider enhanced authentication, especially for privileged access. Management should consider its implementation of cloud services and address the unique access control requirements for cloud environments (refer to the "[Access Control Considerations](#)" section of this booklet). Regardless of the type of operational environment, management should maintain a policy and implement related standards and procedures to identify users and restrict their access (e.g., physical, logical, cloud-based, or privileged) by job function and operational need. For more information, refer to the *IT Handbook's* "[Information Security](#)" booklet.

VI.A.4 Personnel Controls

Personnel controls are critical given the reliance on the operating centers for entity operations. Safe and sound operations rely on skilled personnel, appropriate training, and suitable technology solutions. In coordination with the operations and human resources functions, management should ensure that processes for employee recruitment, hiring, and placement provide for thorough applicant screening and background checks at the time of employment. Background checks should be performed periodically during employment at a frequency consistent with the sensitivity of the position. In addition, management should implement the following personnel controls:

- Clearly define duties, responsibilities, expectations, and accountability to help minimize employee turnover. Turnover disrupts workflow, degrades service and production quality, and increases training resource demands. Staff stability improves employee morale and the effectiveness of operations.
- Implement dual control and segregation of duties to prevent any one person from performing a complete process. The implementation of dual controls and segregation of duties deter employee dishonesty, fraud, or harm to the entity's information and technology assets and serve as a quality control mechanism.
- Independently monitor activities to prevent personnel from validating the accuracy of their own work or that of a superior.
- Implement rotation of duties to facilitate cross-training, improve depth of personnel skill, and augment succession planning.

Adequate segregation of duties is a challenge in smaller or less complex entities. In such circumstances, appropriately implemented rotation of duties can be an effective compensating control. Management should closely review and monitor activities to provide effective supervision, facilitate training, and validate control effectiveness.

VI.B IT Operational Processes

Action Summary

Management should implement effective IT operational processes to reduce the number of potential operational failures and minimize the impact of issues that occur. Management should evaluate the effectiveness of those IT operational processes and adjust them as needed.

Examiners should review for the following:

- Appropriate preventive maintenance or operational restoration processes for equipment within the facilities that support the entity's business objectives.
- Configuration management processes.
- Effective vulnerability and patch management processes.
- Backup and replication processes that facilitate recovery.
- Scheduling processes to manage and effectively use IT resources (e.g., hardware and processing time).
- Capacity management processes that support the entity's current and future strategic objectives.
- Log management processes that allow management to capture system, software, and physical access activities.
- Processes for the appropriate disposal of data and media.

VI.B.1 Maintenance

Maintenance is any act that either prevents the failure or malfunction of equipment or restores its operating capability. Preventive maintenance allows management to proactively address situations that may cause issues or disruptions. Preventive maintenance on equipment minimizes equipment failure and can lead to early detection of potential problems. It can include minor maintenance, such as cleaning peripheral equipment, and more extensive maintenance provided by the manufacturer, vendor, or maintenance contractor. Preventive maintenance includes general housekeeping to keep the data center and its equipment clean and orderly. Unless specifically authorized by management, computer operators should not repair equipment or perform other than the most routine maintenance. Even if computer operators have the requisite knowledge and experience, many hardware and software warranties disclaim liability for unauthorized maintenance or alteration. Routine maintenance by data center employees should be performed according to manufacturers' recommendations.

Maintenance schedules may vary considerably depending on the number and variety of IT systems and the volume of work processed. Preventive maintenance should follow a predetermined schedule. Operations employees should document both internal routine (if any)

and externally provided maintenance in logs and other records. Management review of these records will aid in monitoring any maintenance performed.

Usually, the manufacturer or vendor performs maintenance under contract. For leased equipment, maintenance may be part of the lease arrangement. When equipment is owned or leased from a third party, management should obtain a separate maintenance or service agreement between the entity and the equipment manufacturer or the third party. The service or maintenance agreement should detail the preventive maintenance to be performed, provide for repair services, and include a schedule for maintenance, as well as a time frame for repair.

Management should schedule time and resources for preventive maintenance and coordinate that schedule with production. During scheduled maintenance, management should:

- Limit the service representative's access to the minimum necessary for maintenance on the system.
- Have at least one computer operator present when the service representative is in the computer room or data center.
- Review system activity logs to monitor access to programs or data during maintenance.

When an entity uses hardware from more than one manufacturer, it may be helpful to have an arrangement with a single contractor to manage the entity's preventive maintenance and repair services. The contract or agreement should guarantee timely performance of maintenance.

Some vendors can perform computer maintenance online. Operations personnel should be aware of the online maintenance schedule, so it does not interfere with normal operations and processing. Whether maintenance occurs online or in person, the entity's operations and information security personnel should follow established security procedures to ensure they grant only the necessary access to authorized maintenance personnel at predetermined times to perform specific tasks.

Operations personnel should maintain a log of all hardware or software problems and downtime encountered between maintenance sessions. A periodic report on the nature and frequency of problems is an important management tool and can be valuable for vendor selection, equipment benchmarking, replacement decisions, or planning for increased equipment capacity. Refer to the *IT Handbook's* "[Outsourcing Technology Services](#)" booklet for additional information on managing activities performed by third-party service providers.

VI.B.2 Configuration Management

Configuration management is a collection of activities focused on establishing and maintaining the integrity of IT products and information systems, through control of processes for initializing, changing, and monitoring the configurations of those products and systems throughout the system development life cycle. For a configuration management process to be effective, management should have policies, standards, and procedures and define and implement appropriate configuration settings. In the context of configuration management, configuration settings are the set of parameters that can be changed in hardware, software, or

firmware that affect the security posture and/or functionality of the information system.⁷¹ Defining and applying configuration settings on IT products are important components in operational assurance, along with assessing security controls and conducting a continuous monitoring program. Management should ensure that systems and software used to support the operations of the entity not only have appropriate configuration management capabilities, including configuration of audit log settings, but that the configuration management is enforced. Refer to the *IT Handbook's* "[Information Security](#)" and "[Development and Acquisition](#)" booklets for more information on configuration management.

VI.B.3 Vulnerability and Patch Management

Vulnerability management is a process to continuously acquire, assess, and take action on new information to identify vulnerabilities, remediate, and minimize the window of opportunity for attackers. Part of vulnerability management is patch management. Patch management is the systematic notification, identification, deployment, installation, and verification of OS and application software code revisions.⁷² Vulnerability and patch management are shared responsibilities among an entity's operations and information security personnel. Management should establish procedures to stay abreast of system vulnerabilities and software vendor patches, test the patches in a segregated environment, and install them when appropriate. Refer to the *IT Handbook's* "[Information Security](#)" booklet for more information on vulnerability and patch management.

VI.B.3(a) Vulnerability Management

To have systems that are operationally functional and secure and perform as intended, management should implement a vulnerability management program that identifies systems and software vulnerabilities, prioritizes the vulnerabilities and the affected systems in order of risk, and performs timely remediation, according to the risk associated with the vulnerability. The program should include an entity's systems and software⁷³ operating in the cloud for which the entity is responsible and those managed by the entity on its premises. Management should monitor industry third parties (e.g., United States Computer Emergency Readiness Team [US-CERT⁷⁴], NIST, and Financial Services Information Sharing and Analysis Center [FS-ISAC⁷⁵]) that report vulnerability exposures and address any relevant exposures within the entity's systems and software.

⁷¹ Refer to [NIST SP 800-53 Rev. 5, Security and Privacy Controls for Information Systems and Organizations - PE-3 Physical Access Control](#).

⁷² Examples of software code revisions include patches, hot fixes, and service packs.

⁷³ Examples of systems and software include a port, web application, database, wireless, Bluetooth, and container orchestration.

⁷⁴ The [US-CERT](#) is an organization within the Department of Homeland Security's (DHS) Cyber Security and Infrastructure Security Agency (CISA).

⁷⁵ Refer to [FS-ISAC](#).

Management should implement a process to periodically assess systems and software for vulnerabilities using scanners that are updated with a current vulnerability list. The scans should include all systems and software in the entity's hardware, software, and telecommunications inventories. As with other software tools and utilities, management should implement appropriate controls over vulnerability scanning tools. Controls to protect against unauthorized use or access to sensitive information through the tools include separation of duties, logical security, configuration management, and log review.⁷⁶ The team or person performing the scans should use a dedicated account for authenticated vulnerability scans,⁷⁷ which should not be used for any other administrative activities.

Vulnerabilities are not limited to system or software. Inadequate operational processes can create additional vulnerabilities, exposing entities to unnecessary risk. These vulnerabilities can include weaknesses in security procedures, physical layout, or internal controls that malicious users could exploit to gain unauthorized access to systems or information or to disrupt critical services. Management should have a method to track and report on the remediation progress of all identified vulnerabilities.

VI.B.3(b) *Patch Management*

An important function within operations is patch management. In conjunction with other cyber hygiene practices, a patch management program will allow management to proactively address technology-related system vulnerabilities. An entity's change management procedures should include documentation of any patch installations.

Keeping up with patches in a timely manner is labor-intensive and difficult to manage even for less complex entities; therefore, management should implement automated patch management systems and software to ensure that all network components (e.g., servers, VMs, routers, switches, mobile devices, and firewalls) are appropriately updated. Management should maintain a record of the versions in place and regularly monitor the internet and other resources for information on product enhancements, security issues, patches or upgrades, or other problems with versions of the software in the entity's inventory. Management should be aware of and communicate with its third-party service providers on the need to integrate the entity's patch management program with the third-party service provider's patches or other changes. Refer to the *IT Handbook's* "[Outsourcing Technology Services](#)" booklet. For entities using a cloud environment, management may employ a highly automated update and patch process. Systems and software are often completely rebuilt rather than updated or patched. Refer to the *IT Handbook's* "[Information Security](#)" booklet for more information on patch management.

⁷⁶ Refer to the [Center for Internet Security](#) (also referred to as CIS) Control 3, Continuous Vulnerability Management.

⁷⁷ The University of California at Berkeley's Information Security Office defines an authenticated scan as an essential tool to obtain accurate vulnerability information on covered devices by authenticating to scanned devices to obtain detailed and sensitive information about the OS and installed software, including configuration issues and missing security patches.

VI.B.4 Backup and Replication Processes

A backup is a copy of files and programs made to facilitate recovery. For systems, the backup process includes copying information to a redundant system (e.g., hardware, services, devices, or media) that can provide the same processing capability when the primary system is unavailable. Backups give management the ability to recover operations within a specified time frame, allowing business continuity with limited disruption. Replication involves the use of redundant software or hardware elements to provide availability and fault-tolerant capabilities. Backup and replication processes are shared responsibilities among an entity's operations and business continuity personnel. The decision to implement a specific backup method, including replication, should be based on the risk and criticality of the systems and data.

Management should maintain the following:

- Policies, standards, and procedures that document the entity's backup methodologies, delineate responsibilities of personnel, and promote uniform performance throughout the entity.
- Inventories of backup media, storage location, and access controls for the media or physical location.
- Documented periodic physical reviews to confirm that all relevant backup material is available.
- Procedures to verify adherence to backup schedules.
- Processes to regularly test backup copies for readability.
- Capability to restore operations to a previous trusted state.
- Backups of configurations and data off-site and on a separate system or media.
- VM versioning, replication, and life cycle policies for backup processes.
- Data encryption and access controls to protect backup or replicated data from unauthorized access, destruction, or corruption.⁷⁸
- Proper sanitization⁷⁹ and disposal of data when they are no longer needed to prevent the disclosure of information to unauthorized users.

For entities that rely on third-party service providers, including cloud service providers, to manage backup and replication processes, management should validate that the third-party service provider performs the processes above.

Refer to the *IT Handbook's* "[Business Continuity Management](#)" and "[Information Security](#)" booklets for more information on backup and replication processes.

⁷⁸ Refer to the U.S. Department of Homeland Security's [Cloud Security Strategy: .gov Cloud Security Baseline](#).

⁷⁹ [NIST SP 800-53 Rev. 5, Security and Privacy Controls for Information Systems and Organizations](#), states that "sanitization techniques, including clearing, purging, cryptographic erase, and destruction, prevent the disclosure of information to unauthorized individuals when such media is reused or released for disposal."